

資訊安全稽核查核表

稽核日期：2026/08/30

稽核範圍：資訊安全管理系統 (ISMS) 實施範圍，涵蓋 OT 監控、機房 / 網路維護及 syslog 證據追溯作業。本次 Phase 1 抽樣 ISO/IEC 27001:2022 Annex A 六項 OT 控制項；ot/ 日誌 3 檔；設備：C9300-48p、C9300-24p_2

受稽核單位：OT 監控與維護單位

項次	稽核要點	依據文件	稽核發現					稽核說明
			符合	不符合	觀察事項	建議事項	不適用	
1	資訊安全管理制度	ISO27001 本文						
1.1	組織是否依內外部議題決定 ISMS 範圍與目標？	本文 4.1				V		待改善。ISMS 範圍雖已界定，但部分 OT KPI 未達標，需重新檢視目標設定，以確保 ISMS 範圍與組織的實際運營需求保持一致。
1.2	是否識別會影響 ISMS 之利害關係人及其需求？	本文 4.2				V		待改善。利害關係人需求與 OT 監控結果部分不一致，需更新需求盤點，以確保 ISMS 範圍能充分涵蓋所有相關利害關係人的安全要求。
1.3	ISMS 範圍是否文件化並可稽核追溯？	本文 4.3				V		待改善。範圍文件與實際監控覆蓋仍有落差，需補齊紀錄，以確保 ISMS 範圍文件能準確反映現行的 OT 監控覆蓋情況，並具備可稽核追溯性。
1.4	是否建立、實施、維護並持續改善 ISMS？	本文 4.4				V		待改善。部分控制項 KPI 未達標，需納入管理審查追蹤改善，以確保 ISMS 的建立、實施、維護並持續改善的流程能有效運作。
1.5	資安政策是否經高階管理層核准並傳達？	本文 5.1				V		待改善。政策要求與 OT 現場執行仍有差距，需加強宣導與複核，以確保資安政策能有效傳達至 OT 現場執行層，並獲得高階管理層的充分核准。
1	資訊安全傳輸與加密管理	A.8.24						
1.1	SNMP / TLS / IKE 等加密傳輸事件是否完整記錄並可稽核追溯？	A.8.24	V					是。針對控制項 A.8.24 密碼學與網絡傳輸安全校驗，已收集到 5962 筆 A.8.24 相關 syslog (C9300-48p)，例如 %PKI-3-CERTIFICATE_INVALID、%CRYPTO-4-IKMP_NO_SA、%SNMP，證明加密傳輸事件已完整記錄並可稽核追溯。
1.2	是否出現憑證失效、CRL 無法取得或 IKE 協商失敗等異常？	A.8.24				V		待改善。日誌出現憑證 / 加密協商異常 (%PKI-3-CERTIFICATE_INVALID、%CRYPTO-4-IKMP_NO_SA、%CRYPTO-5-IKEV2_SESSION_STATUS)，需複核相關日誌，以確認憑證失效、CRL 無法取得或 IKE 協商失敗等異常事件的處理狀態。

項次	稽核要點	依據文件	稽核發現					稽核說明
			符合	不符合	觀察事項	建議事項	不適用	
2	組態變更與介面管理	A.8.19						
2.1	介面 UPDOWN、組態變更事件是否有對應變更單或維護窗口？	A.8.19	V					是。針對控制項 A.8.19 變更組態管理稽核，已記錄 14443 筆 (%LINK-3-UPDOWN) 的組態 / 介面事件，建議比對變更單與維護窗口，以確認介面 UPDOWN、組態變更事件是否對應有正式的變更單或維護窗口。
2.2	組態 / 介面事件量是否超出 OT 環境基線？	A.8.19	V					否。組態 / 介面事件量 14443 筆，落在 OT 環境基線範圍內，雖然觀察到介面狀態在特定時間點重複切換，但總事件量未超出基線，因此符合控制項要求。
3	存取控制與身分驗證	A.5.15						
3.1	管理面登入 (SSH / Telnet / Console) 是否可追溯到帳號與來源？	A.5.15	V					否。針對控制項 A.5.15 存取控制，已記錄 16117 筆 (%SEC_LOGIN-5-LOGIN_SUCCESS、%SYS-6-LOGOUT、%SYS-6-TTY_EXPIRE_TIMER) 的存取 / 登入事件，可追溯到帳號與來源，符合可追溯性要求。
3.2	是否出現異常登入失敗、非白名單來源或共用帳號？	A.5.15		V				否。存取控制 KPI 16117 AUTHS 未通過，存在異常登入或未授權存取風險，需立即針對異常登入失敗、非白名單來源或共用帳號等事件進行深入調查與修正。
4	技術弱點與韌體修補	A.8.8						
4.1	IOS-XE 版本 / 映像與弱點修補狀態是否納入資產清冊？	A.8.8	V					是。弱點 / 版本相關事件 10561 筆 (%IOSXE-3-PLATFORM) 已納入監控並可對照資產清冊，雖然日誌顯示與硬碟相關的狀態變更訊息，但已納入監控範圍，符合資產清冊納入要求。
4.2	是否出現 BOOTLOADER / IMAGE 相關異常需安排維護？	A.8.8				V		待改善。日誌出現 BOOTLOADER / IMAGE 或版本異常 (PATCH HINTS 10561)，特別是涉及儲存設備狀態變更的訊息，可能指示系統存在未修補的技術弱點，需立即安排維護窗口進行修補。
5	供應商與外部連線安全	A.5.19						
5.1	CDP / 外部協定警告 (VLAN mismatch 等) 是否在可控範圍？	A.5.19				V		待改善。稽核發現共計 5429 筆與 CDP / 鄰接協定警告 (如 %CDP-4-NATIVE_VLAN_MISMATCH、%CDP-4-DUPLEX_MISMATCH 等) 相關的事件，這些事件所反映的 VLAN / 雙工設定已超出可控範圍，需立即採取改善措施。
5.2	外部連線 / 供應商通道是否有對應風險評估紀錄？	A.5.19				V		待改善。針對 OT 5.2 外部連線與供應商通道的風險評估，稽核發現外部連線事件 5429 筆的紀錄尚未見完整供應商風險評估對應紀錄，需針對此 KPI (EXTERNAL (5429) (review)) 進行改善。

項次	稽核要點	依據文件	稽核發現					稽核說明
			符合	不符合	觀察事項	建議事項	不適用	
6	端點惡意程式防護	A.8.7						
6.1	IPS / 惡意事件 syslog 是否為零或可解釋之測試？	A.8.7		V				否，針對控制項 ot:6.1 的稽核發現，在監控期間，系統記錄了共計 3454 筆與惡意軟體相關的事件，其狀態為「fail」，具體訊息為「INFECTION」，此非零事件未能解釋為測試或誤報，與 KPI 3454 INFECTION (fail) 不符。
6.2	惡意事件是否已隔離並保全證據？	A.8.7		V				否，針對 KPI 3454 INFECTION 的惡意事件，目前尚未完成隔離與證據保全程序，需立即依事件單進行處置。